

Network Security

Chapter 4



SOMAIYA
VIDYAVIHAR UNIVERSITY

K J Somaiya College of Engineering



Network security principles

Confidentiality: Ensuring only authorized users access data.

Integrity: Maintaining data accuracy and preventing unauthorized alteration.

Availability: Ensuring consistent, reliable access to network resources.

Authentication: Verifying the identity of users and devices.

Authorization/Access Control: Limiting access to network resources based on roles.

Non-repudiation: Ensuring parties cannot deny their actions.

Zero Trust Model: "Never trust, always verify" approach to security.

Network Security Protocols

- **SSL/TLS (Secure Sockets Layer/Transport Layer Security)**: Secures web traffic (HTTPS) and encrypts data transmission.
- **IPsec (Internet Protocol Security)**: Secures communications across IP networks, frequently used for VPNs.
- **SSH (Secure Shell)**: Provides secure command-line access to remote servers.
- **SFTP (Secure File Transfer Protocol)**: Transfers files securely over SSH.
- **SNMP (Simple Network Management Protocol)**: Manages and monitors network devices securely.
- **ICMP (Internet Control Message Protocol)**: Used for diagnostics, but must be secured against exploits

- Threats to Network Communications –
 - Interception
 - Modification
 - Fabrication
 - Interruption



SOMAIYA
VIDYAVIHAR UNIVERSITY

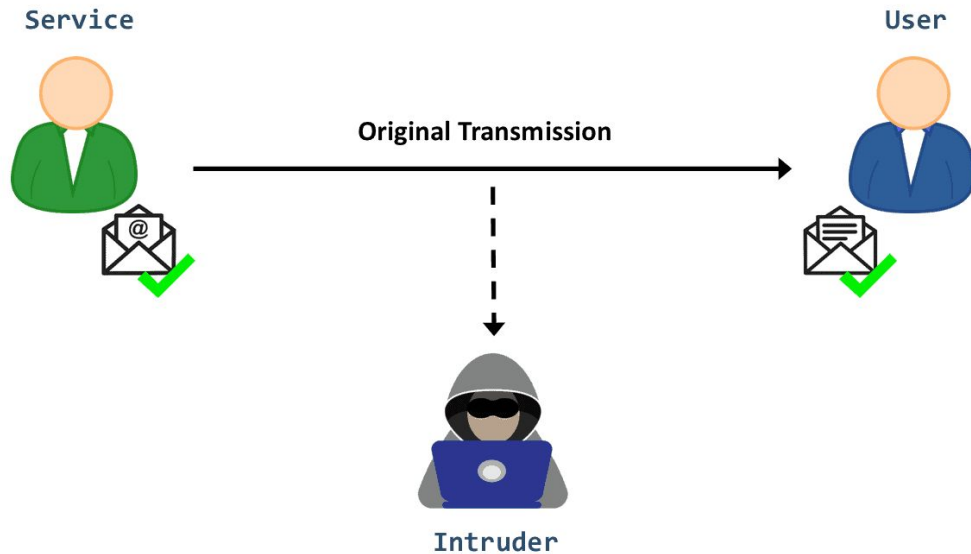
K J Somaiya College of Engineering



Interception

- In the case of an interception attack, a **malicious actor can access private or confidential information with no legitimate authorization.**
- Eavesdropping attacks are a typical example of this category of **attack**. Namely, an intruder can refer to several techniques, such as packet sniffing and man-in-the-middle (MITM).
- Generally, he aims to obtain critical information such as passwords and credit card numbers or to disturb data exchanges on the network. When effectively executed, it can be very hard to identify traces of the attack.

Interception



This category of attacks is mainly a threat to data confidentiality. We can mitigate it by encrypting communications, avoiding untrusted Wi-Fi networks, and regularly updating our software.



SOMAIYA
VIDYAVIHAR UNIVERSITY

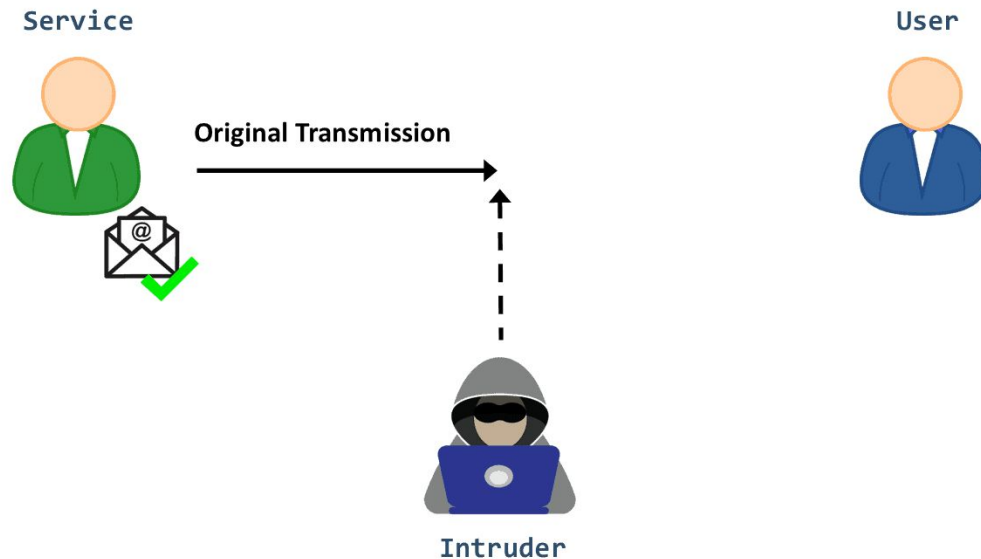
K J Somaiya College of Engineering



Interruption

- **This form of attack manifests when a network service or a system asset is disrupted or destroyed:**
As a result, legitimate users can no longer reach it, either permanently or temporarily.
- For example, an attacker may steal or damage a hardware/software component. **He can also overwhelm a server host with requests so that it can't respond, causing a [DoS attack](#).**
- Another example is using malware, such as viruses or [trojans](#), to delete data or disable a system's functioning.
- **This type of attack is a threat to data availability.**

Interruption



To protect against interruption attacks, **we need appropriate precautions such as firewalls and system backups.** Moreover, we can use [cloud](#)-based solutions and [Content Delivery Networks \(CDN\)](#) to boost security against these attacks and keep our system and network operable.



SOMAIYA
VIDYAVIHAR UNIVERSITY

K J Somaiya College of Engineering



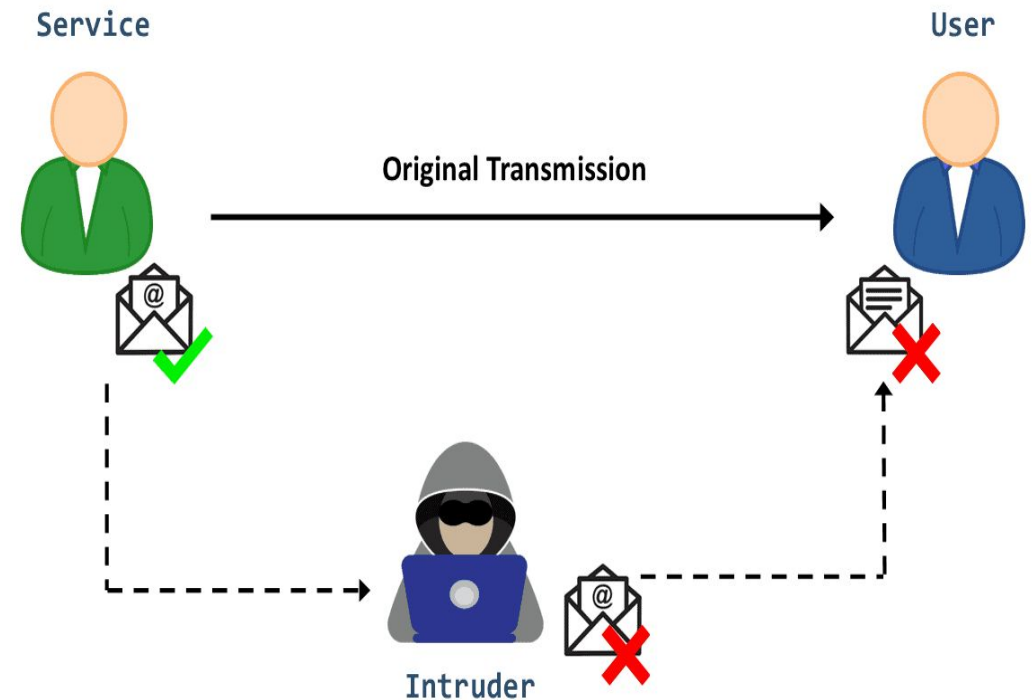
Modification

This one involves not only gaining access to the asset but also manipulating it:

The [man-in-the-middle attack \(MITM\)](#) is a notable **example**. After intercepting data, the attacker can reconfigure the system hardware, remove a message in a network or modify its content. [Cross-Site Scripting \(XSS\)](#) attack is a second example where the hacker injects malicious script into a web application to alter its content or to obtain sensitive data illicitly.

Modification

- **Modification is primarily an attack on integrity.** However, it can also manifest as an attack on availability. For example, let's say the target is a configuration file that controls how a service is delivered. When manipulating its content, that service will no longer be available.
- We can implement several techniques to prevent a modification attack, including [Intrusion Detection Systems \(IDS\)](#), data encryption, and [Access Controls](#).



Fabrication

Fabrication occurs when an intruder injects bogus data or creates a false trail in the system. For example, a hacker can execute identity spoofing by creating a fake version of a legitimate user. Then, he can attempt to commit fraud or hijack a bank account:

- Further, there are other techniques to carry out a fabrication attack, such as [SQL injection](#) and [phishing attacks](#).
- **Fabrication attacks mainly affect data authentication.** That's the case when the intruder creates a spoofing attack and impersonates a user's identity or IP address. Meanwhile, **fabrication can also threaten the availability objective of the [CIA triad](#)**; for instance, injecting an overdose of traffic into a network can block a service.



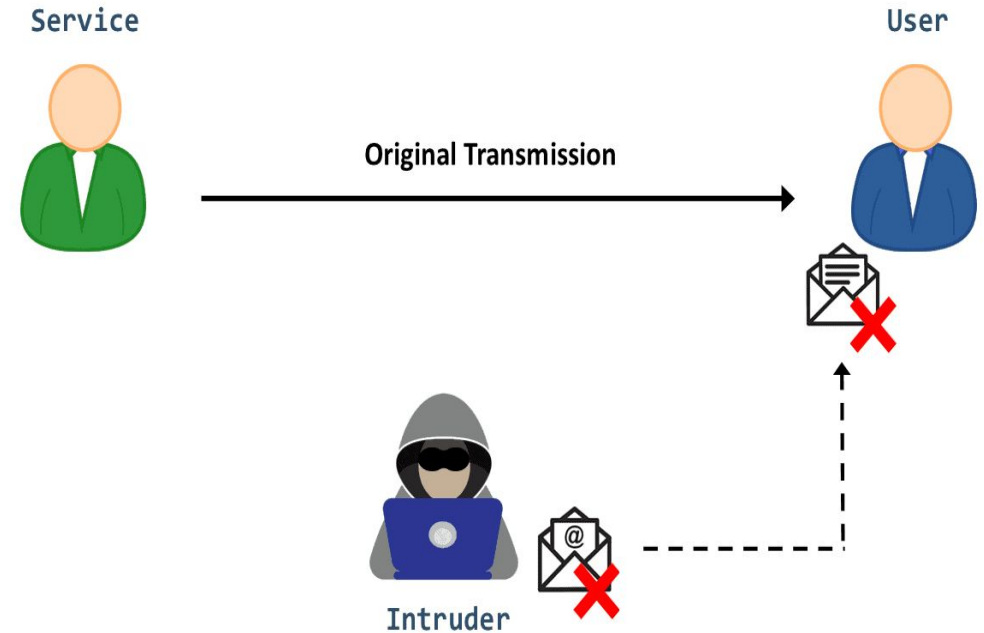
SOMAIYA
VIDYAVIHAR UNIVERSITY

K J Somaiya College of Engineering



Fabrication

- We can mitigate fabrication attacks by using [digital signatures](#) and data encryption or by implementing [firewalls](#) in the network.



Attack Category	Characteristics	Examples	Type
Interception	An unauthorized actor access a service or information shared between two legitimate users	•Eavesdropping •Passwords attacks •Packet sniffing	Passive
Interruption	An unauthorized actor disrupts a service or destroys hardware	•Hardware disruption •Message corruption •Denial of Service •Malware	Active
Modification	An unauthorized actor gains access to a service or data and tampers with the content	•MITM attack •Cross-Site Scripting (XSS)	Active
Fabrication	An unauthorized actor inserts malicious data in the system	•Spoofing •SQL Injection •Phishing •Replay attacks	Active



SOMAIYA
VIDYAVIHAR UNIVERSITY

K J Somaiya College of Engineering



Attack Category	CIA Triad	Mitigation Techniques
Interception	Confidentiality	•Encrypt transferred data •Use trusted wifi-networks •Regular update of the software (OS, applications, passwords, etc.)
Interruption	Availability	•Firewalls •System backups •CDN
Modification	Integrity and Availability	•Intrusion Detection Systems (IDS) •Data Encryption •Access Controls
Fabrication	Authentication and Availability	•Firewalls •Digital signatures



SOMAIYA
VIDYAVIHAR UNIVERSITY

K J Somaiya College of Engineering



Securing communication

- Securing communication over networks involves protecting data confidentiality, integrity, and authenticity. The primary mechanisms for this are **SSL/TLS** (Transport Layer Security), **IPSec** (Internet Protocol Security), and **HTTPS** (HyperText Transfer Protocol Secure), which apply cryptographic protocols to web browsing and network traffic



SOMAIYA
VIDYAVIHAR UNIVERSITY

K J Somaiya College of Engineering



SSL/TLS (Secure Sockets Layer/Transport Layer Security)

- SSL/TLS provides secure communication over networks, primarily for web traffic. While SSL was the predecessor, TLS is the modern standard.
- **Layer of Operation:** Operates between the Transport Layer (TCP) and Application Layer.
- **Architecture:**
 - **Handshake Protocol:** Allows authentication and negotiation of encryption algorithms and keys before data transfer.
 - **Record Protocol:** Takes application data, fragments it, compresses it, appends a Message Authentication Code (MAC), encrypts it, and transmits it.
 - **Alert Protocol:** Handles errors and connection closures.



SOMAIYA
VIDYAVIHAR UNIVERSITY

K J Somaiya College of Engineering



SSL/TLS (Secure Sockets Layer/Transport Layer Security)

- **Workflow:**
- **Client Hello:** Client sends supported TLS versions and cipher suites.
- **Server Hello & Certificate:** Server selects algorithms, sends its digital certificate (containing public key), and "Server Hello Done".
- **Key Exchange:** Client verifies the certificate, generates a pre-master secret, encrypts it with the server's public key, and sends it.
- **Session Key Generation:** Both parties generate symmetric session keys from the pre-master secret.
- **Finished:** Both send a "finished" message, confirming subsequent data is encrypted.



SOMAIYA
VIDYAVIHAR UNIVERSITY

K J Somaiya College of Engineering



HTTPS (HyperText Transfer Protocol Secure)

- HTTPS is not a distinct protocol, but rather HTTP running on top of an SSL/TLS encrypted connection.
- **Layer of Operation:** Application Layer.
- **Architecture:** HTTPS = HTTP + SSL/TLS.
 - **Port:** Operates on port 443 (HTTP uses 80).
 - **Certificate Authority (CA):** Issues certificates to verify server identity.

HTTPS (HyperText Transfer Protocol Secure)

Workflow:

Connection Request: Client requests to connect to a website (e.g., <https://example.com>).

- **TLS Handshake:** The browser and server perform the TLS handshake to verify the certificate and establish session keys.
- **Secure Transmission:** Once established, all HTTP data (requests/responses) is encrypted by the TLS Record Protocol and sent securely

IPSec (Internet Protocol Security)

- IPSec is a suite of protocols that secures IP communications by authenticating and encrypting each packet.
- **Layer of Operation:** Network Layer (Layer 3).
- **Architecture:**
 - **Authentication Header (AH):** Provides data integrity and authentication but no encryption.
 - **Encapsulating Security Payload (ESP):** Provides confidentiality (encryption), authentication, and integrity.
 - **Security Association (SA):** Establishes shared security parameters (keys, algorithms) between peers.
 - **Internet Key Exchange (IKE):** Manages key exchange and negotiates SAs.
-



SOMAIYA
VIDYAVIHAR UNIVERSITY

K J Somaiya College of Engineering



IPSec (Internet Protocol Security)

- **Modes of Operation:**

- **Transport Mode:** Encrypts only the payload of the IP packet; used for end-to-end communication.
- **Tunnel Mode:** Encrypts the entire IP packet (header + payload) and encapsulates it in a new packet; used for VPNs.

- **Workflow:**

- **IKE Phase 1:** Peers negotiate security policies and establish a secure channel (IKE SA).
- **IKE Phase 2:** Using the secure channel, peers negotiate IPSec SAs for the actual data transfer (ESP or AH).
- **Data Transmission:** Data is encapsulated (ESP/AH), encrypted, and transmitted.
- **Termination:** The IPSec tunnel is closed when data transfer is finished or the SA expires.



SOMAIYA
VIDYAVIHAR UNIVERSITY

K J Somaiya College of Engineering



Authentication mechanisms

- Authentication mechanisms verify user identity to secure access to systems, ranging from traditional passwords to advanced, multi-layered approaches.
- Key methods include **knowledge-based passwords**, **biological-based** biometrics (fingerprints, facial recognition), and **2FA**, which requires two different factors, such as a password plus a temporary token



SOMAIYA
VIDYAVIHAR UNIVERSITY

K J Somaiya College of Engineering



Access control models

- Access control models define how systems identify, authenticate, and authorize users to secure resources, with key types:
 - Discretionary Access Control (DAC),
 - Mandatory Access Control (MAC),
 - Role-Based Access Control (RBAC),
 - Attribute-Based Access Control (ABAC).
- These models manage access via owner discretion, security labels, job functions, or dynamic attributes

- **Discretionary Access Control (DAC)**: Access is controlled by the resource owner. It is flexible but less secure, suitable for small environments.
- **Mandatory Access Control (MAC)**: A centralized authority enforces access based on security levels and labels, often used in government or military settings.
- **Role-Based Access Control (RBAC)**: Permissions are assigned based on job roles within an organization, simplifying large-scale management.
- **Attribute-Based Access Control (ABAC)**: A highly flexible model that uses dynamic policies based on user, resource, and environment attributes.
- **Rule-Based Access Control (RuBAC)**: Access is granted based on specific, predefined rules, such as time-of-day restrictions.

Access control models

- Access control models define how systems identify, authenticate, and authorize users to secure resources, with key types:
 - Discretionary Access Control (DAC),
 - Mandatory Access Control (MAC),
 - Role-Based Access Control (RBAC),
 - Attribute-Based Access Control (ABAC).
- These models manage access via owner discretion, security labels, job functions, or dynamic attributes

Network-based attacks

- **Denial-of-Service (DoS) and DDoS**: Attackers flood systems with traffic, disrupting availability.
- **Man-in-the-Middle (MITM)**: Attackers secretly intercept or alter communication between two parties.
- **Packet Sniffing**: Capturing data as it moves through the network to steal credentials.
- **IP Spoofing**: Creating packets with a fake source address to impersonate a trusted host.
- **SQL Injection (SQLi)**: Inserting malicious SQL code into input fields to query or alter databases.
- **Malware/Ransomware**: Viruses, worms, and ransomware that spread across networks to damage or lock data.
- **DNS Spoofing/Poisoning**: Redirecting traffic to malicious websites by hijacking DNS requests

DoS attack

- A DoS attack is a malicious attempt to degrade the performance of a server or disrupt its availability.
- This type of attack works by overwhelming the targeted resource with multiple requests, reducing the system resources available and eventually leading to an interruption of service.



SOMAIYA
VIDYAVIHAR UNIVERSITY

K J Somaiya College of Engineering



Types of DoS Attack

- **volumetric attacks** (saturating bandwidth)
- **protocol attacks** (consuming server resources/connection tables)
- **application-layer attacks** (targeting specific apps, often mimicking legitimate traffic)

Volumetric Attacks

- Volumetric Attacks (**Bandwidth Floods**): These aim to saturate the target's network bandwidth, causing congestion.
 - **UDP Flood**: Sends massive volumes of User Datagram Protocol packets to random ports, forcing the server to check for applications and respond with ICMP packets, exhausting bandwidth.
 - **ICMP (Ping) Flood**: Overwhelms the target with ping requests, consuming both incoming and outgoing bandwidth



SOMAIYA
VIDYAVIHAR UNIVERSITY

K J Somaiya College of Engineering



Protocol Attacks

- **Protocol Attacks (State-Table Exhaustion):** These consume resources of network infrastructure devices like firewalls, load balancers, or servers.
 - **SYN Flood (TCP):** Exploits the TCP handshake process by sending multiple SYN requests but never sending the final ACK, leaving connections half-open until the server exhausts its connection table.
 - **Ping of Death:** Malformed or oversized ICMP packets are sent to a target, causing system crashes or malfunctions.
 - **Smurf Attack:** Spoofs the target's IP address and sends ICMP requests to IP broadcast addresses, causing all machines to send responses to the victim.



SOMAIYA
VIDYAVIHAR UNIVERSITY

K J Somaiya College of Engineering



Application Layer Attacks

- Application Layer Attacks (Layer 7): These target specific vulnerabilities in applications (e.g., web servers) rather than network bandwidth, making them harder to detect.
 - **HTTP Flood:** Floods a web server with legitimate-looking HTTP GET or POST requests, exhausting CPU or memory.
 - **Slowloris:** Opens many connections to a web server and holds them open as long as possible by sending partial HTTP requests, preventing other users from connecting.
 - **R.U.D.Y. (R U Dead Yet):** A "low and slow" attack that submits forms with very low speeds to exhaust the server's available connections.



SOMAIYA
VIDYAVIHAR UNIVERSITY

K J Somaiya College of Engineering

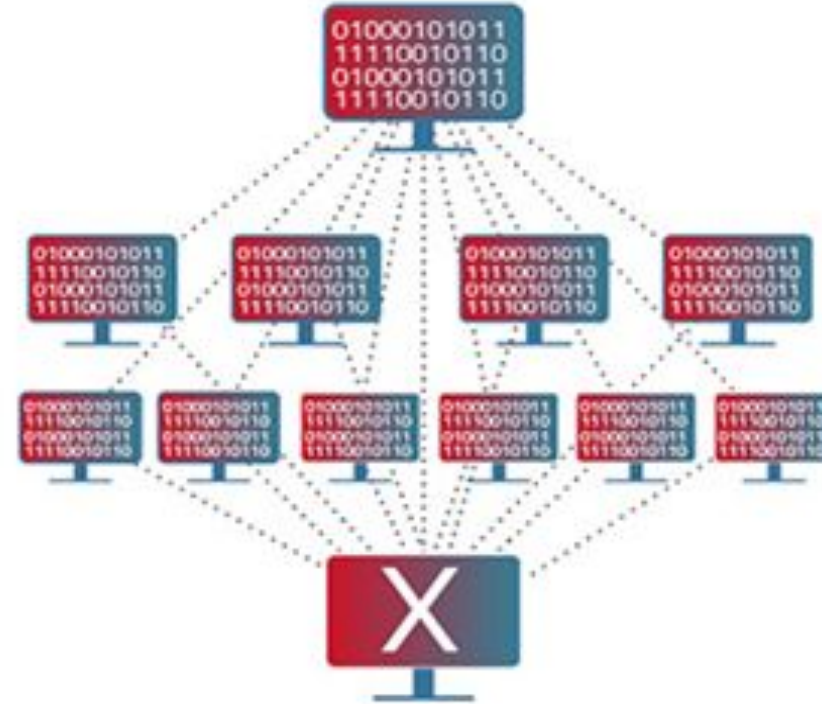


Difference between DoS and DDoS

01000101011
11110010110
01000101011
11110010110



DoS attack



DDoS attack



SOMAIYA
VIDYAVIHAR UNIVERSITY

K J Somaiya College of Engineering



Difference between DoS and DDoS

Criteria	DoS Attack	DDoS Attack
Definition	A DoS attack is an attempt to make an online service unavailable by overwhelming it with traffic from a single source	A DDoS attack is an attempt to make an online service unavailable by overwhelming it with traffic from multiple sources
Source of Attack	Single source, usually one machine or IP	Multiple sources, coordinated botnets, or compromised IPs
Complexity	Relatively simple and easy to execute	More complex, requires coordination and larger resources
Volume of Traffic	Lower volume of traffic	Significantly higher volume of traffic
Detection and Mitigation	Easier to detect and mitigate as traffic comes from a single source	Harder to detect and mitigate due to traffic coming from many different sources
Impact	Limited impact on the target	Severe impact, capable of overwhelming the target



Man-in-the-Middle (MitM) attack

- A Man-in-the-Middle (MitM) attack is a cyberthreat where an attacker secretly intercepts and relays communications between two parties—such as a user and a website—to steal sensitive data like login credentials or credit card numbers.
- These attacks, also known as on-path or adversary-in-the-middle attacks, allow attackers to eavesdrop or manipulate, "acting as proxies" to steal information without either party knowing.



SOMAIYA
VIDYAVIHAR UNIVERSITY

K J Somaiya College of Engineering



Types of MitM Attacks

- **ARP Spoofing:** Linking the attacker's MAC address with a legitimate IP address on a network to intercept traffic.
- **DNS Spoofing:** Modifying DNS records to direct users to a fraudulent website.
- **HTTPS Spoofing/SSL Stripping:** Downgrading secure HTTPS connections to unencrypted HTTP to read data.
- **Evil Twin Wi-Fi:** Creating a fake, malicious Wi-Fi hotspot that looks legitimate to steal data from users who connect



SOMAIYA
VIDYAVIHAR UNIVERSITY

K J Somaiya College of Engineering

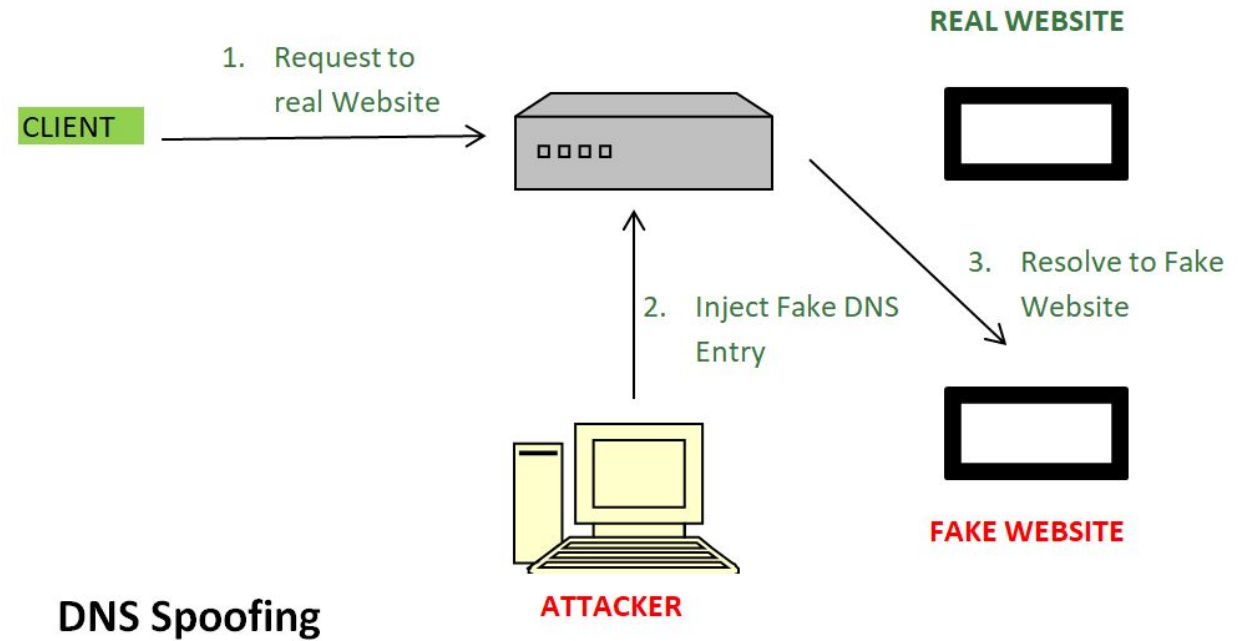


DNS Spoofing

Request to Real Website: User hits a request for a particular website it goes to the DNS server to resolve the IP address of that website.

Inject Fake DNS entry: Hackers already take control over the DNS server by detecting the flaws and now they add false entries to the DNS server.

Resolve to Fake Website: Since the fake entry in the DNS server redirect the user to the wrong website.



DNS Spoofing

Importance of Firewalls

- A firewall is the first line of defense in cybersecurity, acting as a security barrier between internal systems and external networks. It forces all traffic through a single checkpoint, where data packets are monitored, filtered, and either allowed or blocked based on predefined rules. Firewalls are essential because they:
 - **Prevent Unauthorized Access:** Like a locked door with a guard, only trusted users and traffic are allowed through.
 - **Block Malicious Traffic:** Harmful data such as viruses, phishing attempts, or denial-of-service (DoS) attacks are stopped before reaching the system.
 - **Protect Sensitive Information:** Safeguards personal and business data from theft or accidental leaks.
 - **Control Network Usage:** Enforces policies such as parental controls, workplace restrictions, or government filtering.
 - **Mitigate Insider Risks:** Detects suspicious applications or data exfiltration attempts from within the network.



SOMAIYA
VIDYAVIHAR UNIVERSITY

K J Somaiya College of Engineering





Types of Firewall Technology



© iifis.org



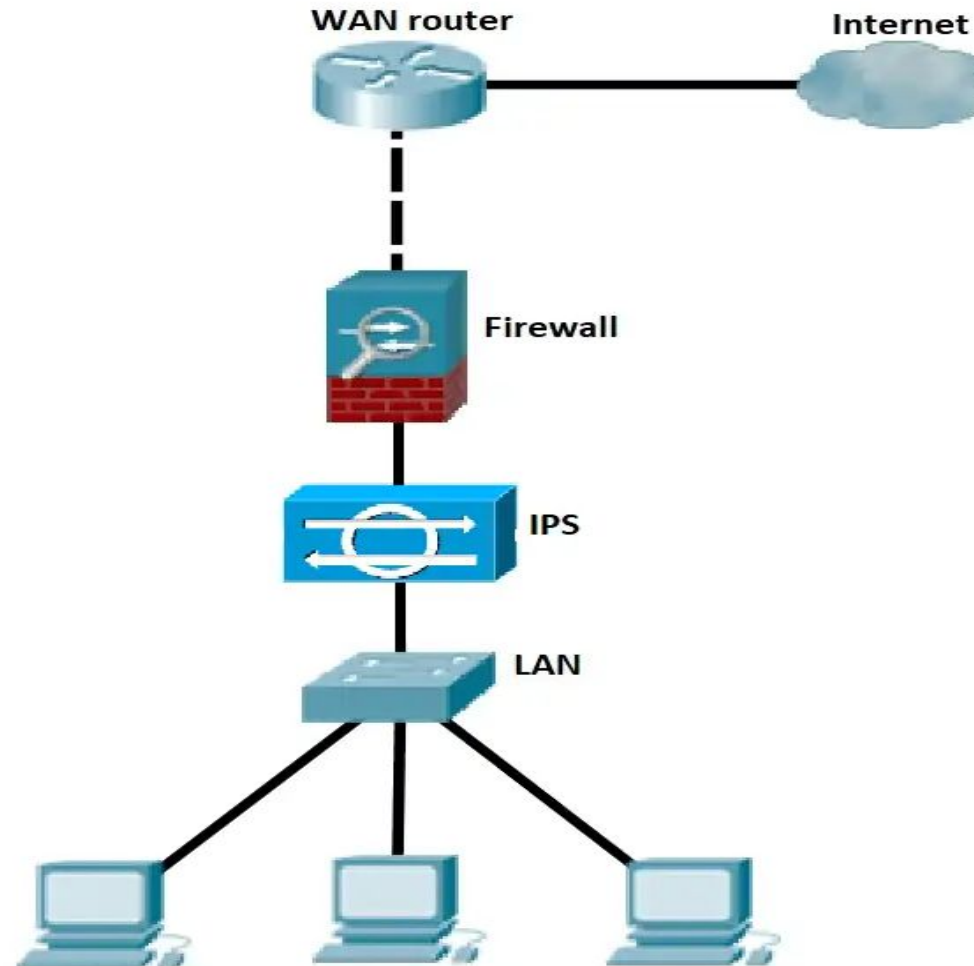
SOMAIYA
VIDYAVIHAR UNIVERSITY

K J Somaiya College of Engineering



Intrusion Prevention System (IPS)

- IPS is a device that inspects, detects, classifies, and proactively prevents harmful traffic.
- It examines real-time communications for attack patterns or signatures and then blocks attacks when they have been detected.
- Placement and configuration in inline mode and generally being in Layer 2 after the firewall.
- In inline mode, traffic passes into one of the device's ethernet ports and out of the other.
- Intrusion Prevention System must work efficiently to avoid decreasing network performance. It must be quick because exploits might occur anytime. To eliminate threats and false positives, the IPS must detect and respond accurately.
- Some of the actions of IPS include:
 - Alerting network administrators (anomaly-based detection)
 - Dropping the malicious traffic
 - Denying traffic from the source address
 - Reset the connection

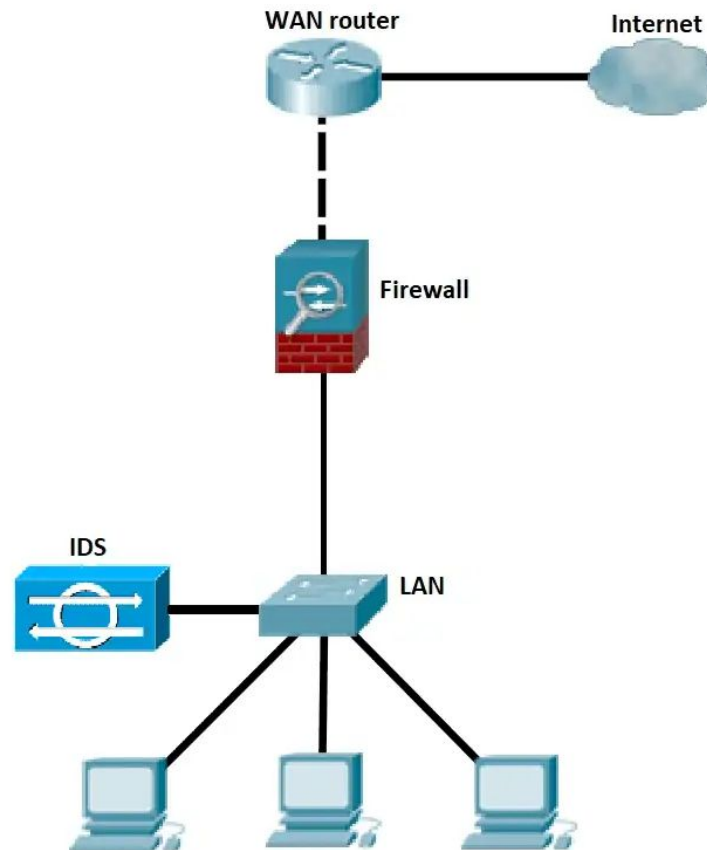


SOMAIYA
VIDYAVIHAR UNIVERSITY

K J Somaiya College of Engineering

Intrusion Detection System

- IDS is either a hardware or software program that analyzes incoming network traffic for malicious activities or policy breaches (network behavior analysis) and issues alerts when they are detected.
- It detects real-time traffic and searches for attack signatures or traffic patterns, then sends out alarms.
- Unlike IPS, a network Intrusion Detection System is not in line with the data path, so it can only alert and alarm on detection of anomalies.



SOMAIYA
VIDYAVIHAR UNIVERSITY

K J Somaiya College of Engineering



Next Generation Firewall

- A Next-Generation Firewall (NGFW) is an advanced network security device that goes beyond traditional packet filtering by integrating deep packet inspection, application awareness, and threat intelligence to provide comprehensive protection against modern cyberthreats.
- They offer enhanced security by inspecting all traffic, enabling user-based policies, and decrypting SSL/TLS traffic.



SOMAIYA
VIDYAVIHAR UNIVERSITY

K J Somaiya College of Engineering



Key Features of an NGFW

- **Application Awareness and Control:** Identifies and controls applications regardless of port, blocking risky apps.
- **Intrusion Prevention System (IPS):**
 - Scans traffic for malicious activity and automatically blocks threats.
- **Deep Packet Inspection (DPI):** Analyzes the content of packets, not just the headers, to detect malware.
- **Threat Intelligence Integration:** Uses updated feeds to identify the latest threats and malicious IPs.**SSL/TLS**
- **Decryption:** Inspects encrypted traffic for hidden threats.
- **User Identification:** Integrates with directory services to create policies based on users and groups rather than just IP addresses.



SOMAIYA
VIDYAVIHAR UNIVERSITY

K J Somaiya College of Engineering



- **NGFW vs. Traditional Firewall**

Traditional firewalls primarily operate at layers 3 and 4 (network/transport layers), focusing on IP addresses and ports. NGFWs operate at all layers of the OSI model, including the application layer, offering superior visibility and control.



SOMAIYA
VIDYAVIHAR UNIVERSITY

K J Somaiya College of Engineering



Virtual Private Network (VPN)

- A Virtual Private Network (VPN) creates a secure, encrypted tunnel between your device and the internet, protecting data from hackers and surveillance while masking your IP address. It allows for private browsing, bypassing geographical restrictions, and secure access to public Wi-Fi.



SOMAIYA
VIDYAVIHAR UNIVERSITY

K J Somaiya College of Engineering



How VPNs Work

- **Encryption:** Converts your data into unreadable code that only your device and the VPN server can understand.
- **Tunneling:** Routes your traffic through a secure server, hiding your activity from your ISP and hackers.
- **Masking IP:** Replaces your local IP address with one from the VPN server, concealing your physical location.



SOMAIYA
VIDYAVIHAR UNIVERSITY

K J Somaiya College of Engineering



- **Key Benefits & Uses**
- **Public Wi-Fi Security:** Protects sensitive data on insecure networks.
- **Remote Work:** Enables employees to securely access company resources.
- **Streaming & Privacy:** Unlocks region-locked content and hides browsing history.

Wifi Protected Access (WPA)

- WPA also referred to as the draft IEEE 802.11i standard became available in 2003.
- The Wi-Fi Alliance made it an intermediate measure in anticipation of the availability of the more secure and complex WPA2, which became available in 2004 and is a common short for the full IEEE 802.11i standard.
- In 2003, WPA also known as the TKIP standard became accessible.
- It was meant to be a stopgap measure by the Wi-Fi Alliance before the more complicated and secure WPA2 became available in 2004.
- WPA2 is a common acronym for the entire IEEE 802.11i (or IEEE 802.11i-2004) standard.

- **WAP 1.0/1.1 (1998-1999):** The foundational versions designed for low-bandwidth 2G networks, using WML (Wireless Markup Language) and requiring a WAP Gateway for conversion.
- **WAP 1.2 (1999-2000):** Introduced crucial features like WAP Push, allowing servers to send content to a handset without a direct user request (e.g., via SMS).
- **WAP 2.0 (2002):** A significant overhaul designed for faster networks (e.g., GPRS/3G). It dropped reliance on custom protocols, adopting XHTML Mobile Profile and standard HTTP/TCP, allowing for direct communication with web servers without specialized gateways.



SOMAIYA
VIDYAVIHAR UNIVERSITY

K J Somaiya College of Engineering

